

Appendix — Governance, Security, AI Agents & Regulatory Standards

Governance & QMS

GitHub / GitHub Projects

Source control and sprint planning

Qualio

eQMS — controlled docs, CAPA, training records

ADR format (in repo)

Architecture Decision Records

Slack

Communication only — not a compliance record

Wardley / Value mapping

Value and risk-driven planning

Security

Snyk

Dependency and container vulnerability scanning

Syft

SBOM generation every build

Trivy

Container image scanning

Azure Key Vault

Secrets and certificate management

Cyber Essentials Plus

UK government security baseline

AI Agents

Anthropic Claude API

Primary agentic framework

Code Review Agent

Structured PR review (Z2)

Compliance Agent

Traceability gate at PR time (Z2)

Documentation Agent

Merge-triggered changelog (Z2)

Ops Agent

Alert-triggered issue creation (Z3)

ML Validation Agent

Model drift detection (Z2)

Z2 = Review & CI Gate · Z3 = Operations

Regulatory Standards

IEC 62304

Medical device software lifecycle

ISO 13485

Quality management system

ISO 14971

Risk management

EU MDR Class IIa

CE certification framework

FDA 510(k) / De Novo

US regulatory pathway

GDPR

Data protection

NHS DSPT

NHS data security toolkit

AAMI/ESH/ISO BP standard

Clinical accuracy threshold ($\leq 5 \pm 8$ mmHg)

FDA Cuffless BP Guidance

Jan 2026 clinical performance testing

FDA Cybersecurity Guidance

2023 — SBOM and vulnerability mgmt

Note on SBOM

This SBOM reflects the target platform architecture as described in the presentation. Current state to be validated on day one. In the target architecture, Syft generates a formal machine-readable SBOM (CycloneDX or SPDX format) on every build as a required FDA cybersecurity artefact.

